

EPIC 04 — API Security & Authentication

Task 01 — Authentication Fundamentals

This task is mainly a study/theory task. You need to understand these six concepts:

1. Authentication

Authentication means verifying who the user is.

Example:

Username: raju

Password: 12345

The server verifies the credentials and confirms that the user is Raju.

Simple meaning:

Authentication = **Who are you?**

2. Authorization

Authorization determines what an authenticated user is **allowed to do**.

Example:

Admin → Can create, update and delete users

User → Can only view users

Simple meaning:

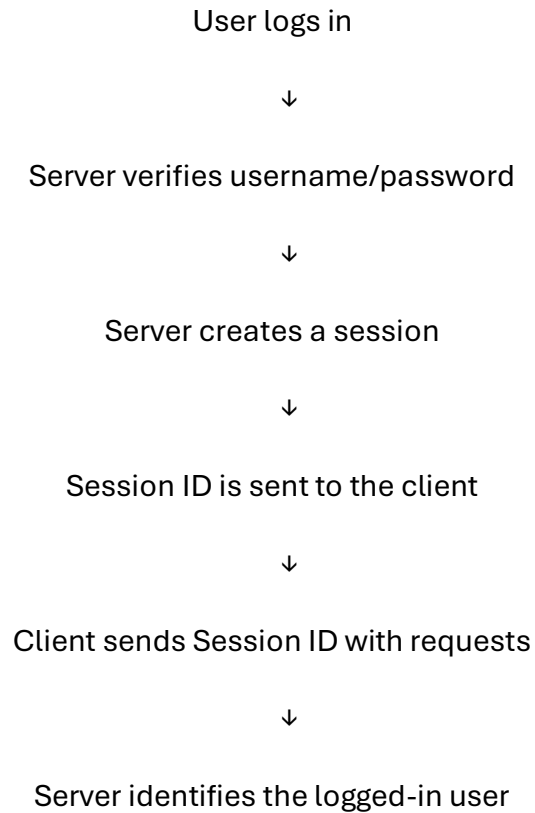
Authorization = **What are you allowed to do?**

Authentication happens first, then authorization.

3. Sessions

A **session** keeps track of a user's login state between multiple requests.

Typical flow:



For example:

Session ID = ABC123XYZ

The server uses this ID to associate requests with the logged-in user.

4. JWT — JSON Web Token

JWT (JSON Web Token) is a token commonly used for authentication in REST APIs.

After successful login:

Username + Password



Server



JWT



Client

The client then sends the JWT with subsequent requests:

Authorization: Bearer <JWT>

A JWT generally contains:

Header

Payload

Signature

Example payload:

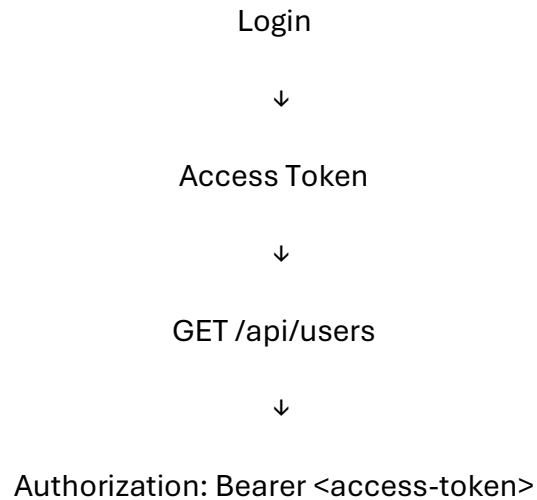
```
{  
  "userId": 101,  
  "username": "raju",  
  "role": "USER"  
}
```

The server verifies the JWT before allowing access to protected APIs.

5. Access Tokens

An **access token** is a credential used by the client to access protected APIs.

Example:



Access tokens are normally **short-lived** for security.

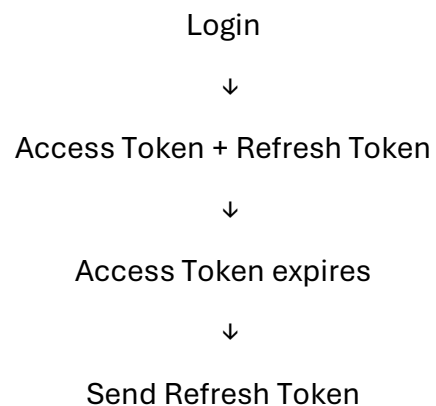
Example:

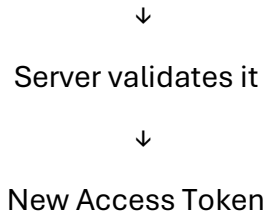
Access token expires → 15 minutes

6. Refresh Tokens

A **refresh token** is used to obtain a **new access token** after the access token expires.

Flow:





For example:

Access Token → expires in 15 minutes

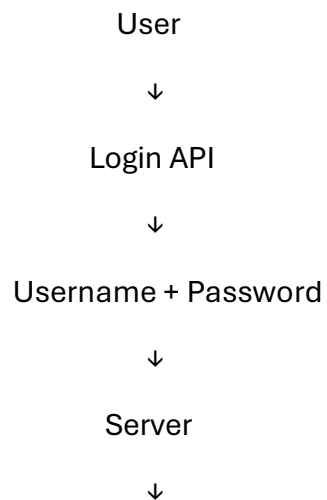
Refresh Token → used to obtain a new access token

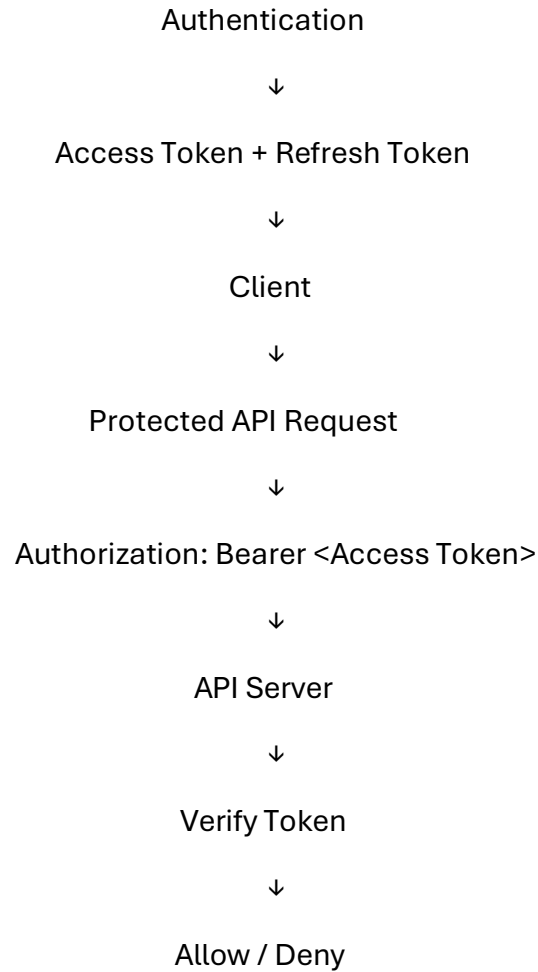
The refresh token allows the user to remain logged in without entering their password again.

Authentication vs Authorization

Authentication	Authorization
Verifies identity	Checks permissions
"Who are you?"	"What can you do?"
Uses username/password, JWT, etc.	Uses roles/permissions
Happens first	Happens after authentication

Complete authentication flow:





Task 01 — We need to know,

- Authentication** → Who are you?
- Authorization** → What can you access?
- Session** → Maintains login state.
- JWT** → Token format commonly used for stateless API authentication.
- Access Token** → Used to access protected APIs.
- Refresh Token** → Used to obtain a new access token.

Task 01 is a study task.

